COMPTIA PENTEST+ · PT0-003 · DOMAIN 4.2 · NETWORK ATTACKS & TOOLS

Perform network attacks using the right tools

This is the most hands-on slice of the exam's biggest domain (Attacks & Exploits, 35%). It won't ask you to recite syntax — it describes an **environment** and asks you to pick the right **attack** and the right **tool**. Four questions decode every scenario: what **condition** makes the attack possible, which **tool** executes it, what **outcome** it produces, and what **risk** it introduces. Attacks chain — so learn each as a link, not a move.

---

§00 the mental model: attacks live on layers

Network attacks span the OSI stack, and the layer tells you the attack's reach and its prerequisite. Anchor every 4.2 technique to where it operates — it makes the "which attack fits this environment" questions fall out almost automatically.

L2 · Data Link
VLAN hopping, ARP spoofing, LLMNR/NBT-NS poisoning — need same-segment access; defeat switching & segmentation.

L3 · Network
Multihomed pivoting, ICMP redirect, packet crafting — cross subnets, bypass firewalls, route through boundaries.

L4 · Transport **Port scans (SYN/NULL/Xmas), relay transport, shells** — TCP/UDP behavior, flag manipulation, connections.

L5–L7 · App
Default creds, misconfigured services, certificate (AD CS), share enum, NTLM relay — abuse trust in services & auth.

PICTURE IT Think of the stack as a building. **L2** is which rooms share a floor (segmentation); **L3** is the hallways between floors (routing); **L4** is the doors and how you knock (TCP handshake); **L7** is what's inside the rooms and who's allowed in (services and credentials). Most Windows-domain attacks live upstairs at L7, but they're reached by owning a door downstairs.

PART A Attack types

Nine network techniques — the conditions that enable each, and the tell that flags it on the exam.

2.1 default credentials

The front-door approach: many devices ship with vendor-set logins that are publicly documented and rarely changed. Lowest effort, highest reward — always the first thing to try.

They persist because admins deploy fast and forget, embedded systems make changes hard, big fleets lose track, and legacy gear lacks modern credential management. You find them by port-scanning, fingerprinting the device/vendor/version, looking up known defaults, and authenticating. Success on network infrastructure yields full admin control — reconfigure routing/firewall rules, then pivot.

PICTURE IT You're not picking the lock — you're trying the key taped under the doormat that the manufacturer left for everyone. `admin/admin` is the doormat.

EXAM TELL Trigger: a **newly deployed device, embedded system, or appliance with no mention of hardening**. Expected action: try vendor defaults before brute force or exploitation. Tools: Hydra, Metasploit auxiliary, Nmap NSE `http-default-accounts`. Key distinction — **default creds are targeted attempts using known values, NOT brute force** (that difference is a common trap).

2.2 on-path attack (MITM)

Formerly "man-in-the-middle." You don't attack a host — you position yourself between two parties and intercept, modify, replay, or strip encryption from their traffic. Power comes from location, not force.

how you get on-path

- **ARP spoofing (L2)** — ARP has no authentication; forged replies map your MAC to the gateway's IP, so victim traffic flows through you. The classic method.
- **DNS poisoning** — corrupt cache entries redirect name lookups to your IP.
- **ICMP redirect** — convince hosts to route through your path.
- **Rogue DHCP** — answer faster than the real server and assign yourself as the default gateway.

Encrypted protocols protect content but not metadata. Combined with positioning, **SSL stripping** (SSLstrip) downgrades HTTPS to HTTP toward the victim while keeping HTTPS to the server — **HSTS** defends this but is bypassable on first visit.

PICTURE IT A dishonest mail carrier who sits between you and the post office. Every letter passes through their hands — they can read it, change it, or copy it — and neither you nor the post office notices, because the envelopes still arrive.

EXAM TELL Trigger: a **switched network, credential interception, or traffic manipulation**. Tools: arpspoof/Metasploit (positioning), Wireshark (capture), Responder (credential capture), Impacket (relay). Key distinction — **you must achieve positioning first**; simply running Wireshark on a switched network does not capture other hosts' traffic (a switch only sends you your own).

2.3 certificate services (AD CS)

These attacks abuse the PKI trust that underpins an enterprise. Active Directory Certificate Services issues certs that carry implicit domain-wide trust — a cert that authenticates as a domain admin effectively is domain control, bypassing every password defense.

ESC	MISCONFIGURATION	RESULT
ESC1	Template lets requester specify a **SAN** + no manager approval	Any user requests a cert for any user (incl. domain admin)
ESC2	"Any Purpose" template / no EKU + broad enrollment	Cert usable for authentication
ESC3	Template allows enrollment as Certificate Request Agent	Request certs on behalf of privileged accounts
ESC4	Low-priv users have **write** over a template	Modify it to introduce ESC1/ESC2
ESC8	**NTLM relay** to the AD CS web-enrollment HTTP endpoint	Cert for the DC's machine account → TGT → DCSync

Once you hold a cert for a privileged account, **PKINIT** requests Kerberos TGTs — full auth without the password. Tools: **Certify** (enumerate), **Certipy** (find + exploit), **Rubeus** (request TGTs), Impacket (the NTLM relay in ESC8).

MNEMONIC The one to burn in is **ESC1 = SAN**. "ES-**C-one**, name any-**one**" — the flaw is that you get to name the subject (SAN), so you name a domain admin. Everything else is a variation on "who can request what."

EXAM TELL Trigger: **AD CS, certificate templates, NTLM relay, or AD CS web enrollment**. Key distinction — these are **authentication attacks abusing PKI trust**, not encryption weaknesses. If the stem pairs "NTLM relay" with "certificate enrollment," that's **ESC8**.

2.4 misconfigured services exploitation

The gap between how a service should be configured and how it actually is. No CVE required — you use the service as designed; it simply trusts you more than it should. High success, low detection, so it's prioritized early.

SERVICE	COMMON MISCONFIGURATIONS
Web (Apache/IIS/Nginx)	Directory listing, verbose errors, exposed `/admin` `/manager` `/phpmyadmin`, accessible `.bak/.old/.zip`
FTP	Anonymous auth, writable directories, cleartext transmission
SMB	Open shares, **null sessions**, **SMB signing disabled** (enables relay)
SNMP	Default community strings (public/private), v1/v2 cleartext, write access
SSH	Root login permitted, password auth enabled, weak host-key algorithms
Databases	sa/blank (MSSQL), root/blank (MySQL), bound to `0.0.0.0`, excessive privileges, **xp_cmdshell** enabled
Network devices	Telnet, HTTP management, default SNMP communities

EXAM TELL Trigger: an **exposed service, default settings, overly permissive access, or a service reachable from an unexpected network**. Tools: Nmap (discovery), Metasploit (exploit), smbclient/CrackMapExec (SMB), Hydra (creds). Key distinction — **it exploits design choices, not software bugs**, so there's no CVE to look up.

2.5 VLAN hopping

Reaching VLANs you're not authorized for, defeating network segmentation. Two distinct techniques — and the exam wants you to tell them apart from the described switch config.

Switch spoofing

Your port negotiates a **trunk** via DTP (Dynamic Trunking Protocol) because it's left in dynamic/auto mode. You impersonate a switch and receive traffic for all VLANs. Establishes a full, **bidirectional** trunk link.

Double tagging

You craft a frame with **two** 802.1Q tags. The first switch strips the outer tag and forwards the inner-tagged frame into the target VLAN. Works only when your VLAN is the **native VLAN** of the trunk. **One-directional** — good for sending, not interactive sessions.

THE DIFFERENCE Switch spoofing = **full trunk, two-way**, via DTP. Double tagging = **one-way**, via the native VLAN. If the stem says "dynamic desirable" or "DTP" → spoofing; if it says "two tags" or "native VLAN" → double tagging.

Tools: **Yersinia** (L2 protocol attacks), **Scapy** (craft double-tagged frames), Wireshark (verify). Defenses: set ports to access mode / `switchport nonegotiate`, change the native VLAN off VLAN 1, tag native traffic.

MNEMONIC **Double tagging = one direction** ("two tags, one way"). The two tags only push the frame outbound into the target VLAN; nothing tags the return trip, so replies never come back. Spoofing builds a real trunk, so it's two-way.

EXAM TELL Trigger: segmentation, VLANs, a switch port in **dynamic mode**, or **double-tagged frames**. Successful VLAN hopping is a **critical finding** because it collapses segmentation entirely.

2.6 multihomed hosts

A host with interfaces on two or more networks at once. Legitimate (firewalls, bastions, DMZ bridges, management NICs) — but compromising one gives a **pivot point** that physically bypasses segmentation, because traffic can flow interface-to-interface inside the host, around the firewall.

Identify them by multiple IPs on one hostname, the same host answering on different subnets, routing/ARP tables on compromised systems, or AD interface attributes. Then compromise, enumerate all interfaces/subnets, and establish routing or tunneling. Pivot tools: **Metasploit route/autoroute**, **sshuttle** (SSH VPN-like tunnel), **Proxychains**, **Chisel** (TCP/UDP over HTTP). Out-of-band management interfaces (IPMI/iDRAC/iLO) are especially juicy — weak auth, old firmware, hardware-level access below the OS.

PICTURE IT A room with two doors, each opening into a different building — one into the public lobby (DMZ), one into the secure vault area (internal). Segmentation assumed no room touched both. Own that room and you walk between buildings without passing the guard desk.

EXAM TELL Trigger: a **server with multiple interfaces**, a host in both DMZ and internal, or a "pivot to reach otherwise inaccessible systems." Key distinction — the attack is about **what the host connects to**, not the host itself; it's discovered during enumeration and exploited as a pivot.

2.7 relay attack

Intercept an authentication attempt and forward it to another system in real time — you authenticate as the victim without ever knowing or cracking the password. Devastating in Windows/NTLM environments.

NTLM is challenge-response: client negotiates, server sends a challenge, client computes a response from the password hash. In a relay you sit on-path, catch the attempt, and forward the exchange to a different target, which grants access as if the user logged in directly. Prerequisite: **SMB signing disabled/not required** on the target (signing requires the key, i.e. the actual password). Relay targets include SMB, **LDAP** (create/elevate accounts), MSSQL, and **AD CS (ESC8)**.

The enabler is **LLMNR/NBT-NS poisoning**: when DNS fails, Windows broadcasts a fallback name query; **Responder** answers, directing the victim to authenticate to you. Then **Impacket's ntlmrelayx** relays it — and can execute commands, dump SAM, or create domain users.

Relay attack

Forwards the authentication exchange **in real time**. Never touches the hash's plaintext. Needs a live authentication event to catch.

Pass-the-hash

Reuses an **already-captured** NTLM hash to authenticate later. No live event needed — you already hold the hash.

THE DIFFERENCE Relay = **forward now**; pass-the-hash = **replay a stored hash later**. If the scenario captures auth and immediately uses it against another box → relay. If it dumps hashes and reuses them → pass-the-hash. This is one of the exam's favorite confusions.

EXAM TELL Trigger: **NTLM auth, SMB signing disabled, LLMNR poisoning, capturing hashes**. Expected action: Responder captures/poisons, ntlmrelayx relays. Tools: Responder + Impacket ntlmrelayx, CrackMapExec (verify).

2.8 share enumeration

Finding and assessing network-accessible shares — file, printer, and admin shares over SMB. Shares hold documents with embedded credentials, config files with connection strings, scripts with hardcoded passwords — fuel for lateral movement.

- **Share types** — standard (user shares), **administrative** (hidden: C$, ADMIN$, IPC$), printer, and special (**SYSVOL/NETLOGON** on DCs, holding GPOs and logon scripts).
- **Null session** — an unauthenticated connection to IPC$ that historically enumerated users/groups/shares; restricted on modern Windows, still present on legacy/misconfigured hosts.
- **GPP cpassword** — SYSVOL Group Policy Preferences once stored credentials encrypted with a publicly known AES key; patched in MS14-025 but lingers in legacy environments.
- **Writable shares** — upload malicious files, or plant `.lnk` shortcuts that trigger NTLM auth when browsed (feeds Responder/relay).

Permissions matter as much as existence: **read** = data/credential theft, **write** = file planting and possible code execution. Tools: **smbclient**, **CrackMapExec** (at scale), **SMBMap** (permission analysis), Impacket smbclient.py, Metasploit smb_enumshares.

EXAM TELL Trigger: **SMB shares, null sessions, SYSVOL, or hunting files/credentials on shares**. It's a step in both recon and lateral movement — accessible shares accelerate the whole engagement. Watch for **GPP cpassword** and **writable-share + .lnk** as relay enablers.

2.9 packet crafting

Manually constructing packets field-by-field to test specific behaviors that automated tools can't replicate. It's about precision and control — mapping firewalls, evading IDS, and building proof-of-concept exploits.

CRAFTED TCP SCAN	FLAGS SET / BEHAVIOR
NULL scan	No flags set
FIN scan	FIN only
Xmas scan	FIN + PSH + URG ("lit up")
SYN flood	Many SYNs, no handshake completion (DoS)
RST injection	Forged RSTs to terminate connections

IP fragmentation splits payloads so older IDS/IPS that reassemble poorly miss the signature. **Scapy** is the primary tool — build packets layer by layer in Python (IP → transport → payload → send → analyze). Use it for firewall/ACL mapping (send specific packets, see which get responses — maps rules without touching the firewall), IDS evasion, and PoC development. Impacket uses packet crafting internally for NTLM relay.

MNEMONIC **Xmas = all lights on** (FIN, PSH, URG). **NULL = lights off** (no flags). Both exploit the same RFC rule: a closed port replies RST, an open port stays silent — so silence = open on these stealth scans.

EXAM TELL Trigger: **testing firewall rules, IDS evasion, custom protocol behavior, or specific packet types**. Tool: Scapy (construction), Wireshark/tcpdump (verify). Key distinction — packet crafting is **precision testing** of behaviors automated scanners can't reproduce.

PART B Tools

Nine tools — each with its one unique capability, because that's what the exam matches to a scenario.

3.1 Metasploit

The world's most-used exploitation framework — scanning, exploitation, and post-exploitation in one interface. For 4.2, know the module types and how Meterpreter enables post-ex.

MODULE / PAYLOAD TYPE	WHAT IT IS
Exploit	Delivers a payload against a specific vuln (rated Excellent → Low)
Auxiliary	Non-exploit: scanning, enumeration, brute force, DoS
Post	Runs after access: cred dumping, priv-esc, lateral movement, persistence
Singles / stagers / stages	Self-contained / small connect-back / the downloaded second component
Meterpreter	Advanced in-memory payload — interactive post-ex shell

Core flow: `search` → `use` → `show options` → `set RHOSTS` → `run` / `exploit` → `sessions -i`. Meterpreter: `getuid`, `getsystem`, `hashdump`, `route add` (pivot), `portfwd`. Network modules: `smb_ms17_010` (check) and `ms17_010_eternalblue` (exploit), `smb_enumshares`, `server/capture/smb`.

EXAM TELL Any question on **automated exploitation, module selection, or post-exploitation**. Know the three module types (exploit/auxiliary/post) and the payload types. For network attacks: SMB exploitation, credential capture, port scanning.

3.2 Netcat

The "TCP/UDP Swiss Army knife" — tiny, versatile, reads/writes raw network connections. Its exam-critical use is creating shells, especially reverse shells that beat inbound firewall rules.

Bind shell

Target opens a listener; attacker connects to it.
`target: nc -lvp 4444 -e /bin/bash`
Blocked by inbound firewall rules on the target.

Reverse shell

Target connects back to the attacker's listener.
`attacker: nc -lvp 4444`
Works through NAT/firewalls — outbound is usually allowed.

THE DIFFERENCE It's about **who listens**. Bind = **target listens**, attacker dials in. Reverse = **attacker listens**, target dials out. Reverse is preferred because firewalls restrict inbound far more than outbound.

Also: port scan `nc -zv` (zero-I/O), banner grab `nc host port`, file transfer with redirection. **Ncat** (bundled with Nmap) adds SSL/TLS, proxy, IPv6. Limitations: no encryption or auth in basic nc; some builds drop the `-e` flag for safety.

EXAM TELL Questions about **creating shells, bypassing firewalls, simple transfer/banner grabbing without heavy tools**. Know bind vs reverse and why reverse wins. Netcat shines on compromised hosts where full tools aren't available.

3.3 Nmap & NSE

The foundational scanner — the start of nearly every engagement. NSE (Lua scripts) turns it into a recon and vuln-detection platform.

FLAG	SCAN / FUNCTION
`-sS`	TCP SYN (stealth, most common, needs root)
`-sT`	TCP connect (full handshake, no root)
`-sU`	UDP scan
`-sF / -sN / -sX`	FIN / NULL / Xmas (stealth flag scans)
`-sV`	Service version detection
`-O`	OS fingerprinting
`-A`	Aggressive: OS + version + scripts + traceroute
`-Pn`	Skip host discovery (treat all as up)
`-T0…-T5`	Timing (paranoid → insane); -T4 typical

Port states: **open** (listening), **closed** (reachable, nothing there), **filtered** (blocked, no response), **open|filtered** (UDP ambiguity), **unfiltered** (ACK-scan result). Key NSE scripts: `smb-vuln-ms17-010` (EternalBlue), `smb-enum-shares`, `http-default-accounts`, `ftp-anon`, `snmp-brute`, `ssl-enum-ciphers`. NSE categories worth knowing: `auth`, `brute`, `vuln`, `safe` vs `intrusive`.

MNEMONIC Lowercase **-s?** = "scan type." Big **-A** = "All the aggressive stuff at once." **-Pn** = "Ping? No." (skip discovery — useful when hosts block ping but are actually up).

EXAM TELL Nearly any discovery question. Match the flag to the goal (`-sS/-sV/-sU/-A`), read port states correctly, and know that **NSE scripts automate the checks** that feed later attacks (e.g. `smb-vuln-ms17-010` confirms EternalBlue).

3.4 Impacket

A Python toolkit implementing Windows network protocols from scratch — the backbone of Windows post-exploitation. It enables protocol-behavior attacks, not software-bug exploits.

IMPACKET TOOL	DOES
ntlmrelayx.py	NTLM relay to SMB/HTTP/LDAP/MSSQL; exec commands, dump SAM, create users
secretsdump.py	Extract SAM, **NTDS.dit**, LSA secrets, cached creds (needs admin)
psexec.py	Remote exec — creates a service (needs admin or hash)
wmiexec.py	Remote exec via WMI — **stealthier, no service created**
GetNPUsers.py	**AS-REP roasting** — accounts without Kerberos pre-auth
GetSPNs.py	**Kerberoasting** — TGS tickets for SPN accounts, crack offline
ticketer.py	Forge Golden/Silver tickets (needs SID + krbtgt hash)

Most tools accept an NTLM hash in place of a password — native **pass-the-hash**. psexec vs wmiexec is a classic pairing: **psexec creates a service (louder), wmiexec uses WMI (quieter)**.

EXAM TELL Windows network attacks — **NTLM relay, credential dumping, remote execution**. Map the name to the job: ntlmrelayx (relay), secretsdump (creds/NTDS.dit), psexec/wmiexec (exec), GetNPUsers (AS-REP), GetSPNs (Kerberoasting).

3.5 CrackMapExec (CME)

The automation layer for Active Directory — test credentials, enumerate, and execute across many hosts at once. Turns single techniques into network-wide sweeps.

Protocols: SMB (primary), WMI, LDAP, MSSQL, SSH, RDP. It tests a credential set against a whole range simultaneously, accepts hashes (**pass-the-hash**), enumerates shares/users/groups, executes commands, and integrates with Mimikatz for dumping. Output is color-coded: green `[+]` success, red `[-]` fail, yellow `[*]` info, and `Pwn3d!` = admin access confirmed.

MNEMONIC See `Pwn3d!` in an answer choice → CrackMapExec, and it means **admin-level** access on that host (not just valid creds). It's CME's signature word.

EXAM TELL AD, **testing credentials across many systems**, share enum at scale, lateral movement. Note the OPSEC angle: sweeping a network is **noisy** and triggers alerts — a likely "what's the risk" answer.

3.6 Wireshark / tcpdump

The eyes of network testing — capture and analyze traffic. Passive tools, but central to on-path attacks: their value is pulling credentials from cleartext protocols and verifying an attack works.

WIRESHARK FILTER	SHOWS
`http.request.method=="POST"`	Form submissions (credentials)
`ftp / telnet`	Cleartext creds / all keystrokes
`ntlmssp`	NTLM authentication
`kerberos`	Kerberos authentication
`ip.addr == x.x.x.x`	Traffic to/from a host

Wireshark also does Follow-TCP-Stream (session reconstruction) and object export. Cleartext credential sources: HTTP Basic, FTP, Telnet, SMTP/POP3/IMAP, SNMP. **Promiscuous mode** is required to see beyond your own interface — but on a switch you still only get your own traffic unless you've achieved on-path position or port mirroring. tcpdump is the CLI equivalent: `-i` interface, `-w` / `-r` PCAP, `-X` hex+ASCII, filters like `host` / `port`.

EXAM TELL Capturing traffic, analyzing packets, **credential interception**, verifying attack success. Know display filters, PCAP files, and the **promiscuous-mode-on-a-switch** caveat — it ties directly back to why on-path positioning is needed (2.2).

3.7 msfvenom

Metasploit's payload factory — generates custom shellcode/executables in any format for any delivery method. The exam-critical concept is staged vs stageless.

Staged (/ separator)

`windows/x64/meterpreter/reverse_tcp`

Small stager connects back and **downloads** the stage. Smaller initial file; needs the callback to succeed.

Stageless (_ separator)

`windows/x64/meterpreter_reverse_tcp`

Everything in one file. Larger, but **no download step** — better with **egress filtering**.

THE DIFFERENCE The separator is the tell: **slash = staged**, **underscore = stageless**. When the scenario mentions **egress filtering**, choose **stageless** (nothing to download). When reliability is the concern, staged is standard.

Syntax: `msfvenom -p [payload] LHOST= LPORT= -f [format] -o [file]`. Formats: exe, elf, raw, py, ps1, asp/aspx, jsp, php, dll. Encoders (`shikata_ga_nai`, `-i` iterations, `-b` bad chars) help evade signatures — though modern AV catches stock payloads. The generated payload connects to a listener: `exploit/multi/handler` with the matching payload/LHOST/LPORT.

EXAM TELL Creating payloads, delivering shellcode, generating web shells, reverse shells. Know **staged vs stageless** (and the egress-filtering rule), output formats, LHOST/LPORT, and that the payload pairs with `multi/handler`.

3.8 Responder

An LLMNR/NBT-NS/MDNS poisoning tool that captures NTLM hashes by abusing Windows name-resolution fallback. The critical first step of most relay attacks.

When DNS fails, Windows broadcasts "who is `fileserver`?" over LLMNR/NBT-NS. Responder answers "me," the victim authenticates to the attacker, and Responder captures the **NTLMv2** hash (also NTLMv1, cleartext creds, sometimes Kerberos). It runs fake SMB/HTTP/FTP/LDAP/SQL servers to catch multiple protocols. Captured hashes can be **cracked offline** (Hashcat/John) or **relayed** (ntlmrelayx).

PICTURE IT You shout a friend's name across a crowded room; before they can answer, an impostor yells "that's me!" and you hand them your ID. Responder is the impostor answering every unmatched name call on the LAN.

WATCH THE MODE For a **relay**, Responder runs in **poison-only mode** (SMB/HTTP servers disabled) so it doesn't grab the auth before ntlmrelayx can forward it. **Analysis mode (`-A`)** only observes — it identifies vulnerable systems without responding. Capture-mode vs poison-only is a subtle distinction worth holding.

EXAM TELL **LLMNR/NBT-NS poisoning, capturing NTLM hashes, or "first step of a relay attack"** → Responder. It captures **NTLMv2**; defenses are disabling LLMNR/NBT-NS and enabling SMB signing.

3.9 Hydra

A fast, parallel online login cracker — it authenticates directly against live services (SSH, FTP, HTTP forms, SMB, RDP, databases, and more). Distinct from offline hash cracking.

Flags: `-l` / `-L` (single/list username), `-p` / `-P` (single/list password), `-t` (threads), `-f` (stop on first hit), `-s` (port). HTTP forms use `http-post-form` with `^USER^` / `^PASS^` markers. Attack styles: brute force, dictionary, **password spraying** (one password across many users — avoids lockout), credential stuffing. Wordlists: **rockyou.txt**, SecLists, CeWL-generated.

Online (Hydra/Medusa)

Attempts logins against a **live service**. Slower, and **risks account lockout** + heavy logging.

Offline (Hashcat/John)

Cracks **captured hashes** locally. Far faster, no lockout, no service noise — but you need the hash first.

THE DIFFERENCE Hydra hits a **live login**; Hashcat chews a **captured hash**. If the scenario has a reachable service and no hash → Hydra. If it already captured hashes → offline cracking. Lockout risk is the Hydra-specific "risk" answer.

EXAM TELL Brute-forcing network services, testing creds against SSH/FTP/HTTP, **password spraying**. Know the online-vs-offline split and that spraying (one password, many accounts) is the lockout-safe approach.

SYNTHESIS How the pieces chain together

Attacks rarely stand alone. These are the canonical chains — and the conditions each requires.

chain 1 — the classic Windows network attack

Nmap → Responder poison LLMNR/NBT-NS, catch NTLMv2 → ntlmrelayx relay to SMB → CrackMapExec test creds across hosts → secretsdump dump creds → CrackMapExec move laterally → Metasploit exploit → msfvenom payloads

needs Windows environment · SMB signing disabled · LLMNR/NBT-NS enabled

chain 2 — network segmentation bypass

Nmap map segment → Wireshark learn topology → VLAN hopping reach restricted VLANs → find multihomed host → compromise it (default creds / misconfig) → autoroute / sshuttle pivot → Nmap scan new segments

needs switched network · misconfigured trunk or native VLAN · hosts spanning zones

chain 3 — service exploitation path

Nmap + NSE discover services → misconfigured services (anon FTP, open SMB, default SNMP) → CrackMapExec/smbclient share enum → Hydra test defaults → Scapy probe firewall/protocol → Metasploit exploit → Netcat reverse shell

needs mixed/legacy environment · poor change management

chain 4 — on-path credential capture

Nmap map → ARP spoofing get on-path → Wireshark/tcpdump capture → identify cleartext (FTP/HTTP/Telnet/SNMP) → extract creds → if encrypted: attack AD CS → if NTLM: relay

needs switched network · on-path achievable · mix of encrypted & cleartext protocols

MAP tool-to-attack matrix

ATTACK TYPE	PRIMARY TOOL	SUPPORTING
Default credentials	**Hydra, Metasploit**	Nmap NSE, CrackMapExec
On-path	**Responder, arpspoof**	Wireshark, Impacket
Certificate services	**Certify, Certipy**	Impacket, Rubeus
Misconfigured services	**Nmap NSE, Metasploit**	CrackMapExec, smbclient
VLAN hopping	**Yersinia, Scapy**	Wireshark
Multihomed hosts	**Nmap, Metasploit**	sshuttle, Proxychains
Relay attack	**Responder + ntlmrelayx**	CrackMapExec, Impacket
Share enumeration	**CrackMapExec, smbclient**	Metasploit, SMBMap
Packet crafting	**Scapy**	Wireshark, tcpdump

the enabling relationships

Responder enables relay attacks — it captures the authentication to forward.

Relay attacks require SMB signing disabled — verified with Nmap NSE.

VLAN hopping enables reaching multihomed hosts — it bypasses segmentation.

Default credentials enable share enumeration — authenticated access reveals more.

On-path positioning enables credential capture — Wireshark reads the cleartext.

msfvenom generates payloads for Metasploit handlers; Netcat establishes the shell after exploitation.

CRAM Confusables the exam blurs on purpose

If two things feel similar, the exam will test exactly that seam. One-line separations to lock in.

THIS	VS. THAT	THE SEAM
Relay attack	Pass-the-hash	Forwards auth **in real time** vs. reuses an **already-captured hash** later
Reverse shell	Bind shell	**Attacker listens**, target dials out (beats firewalls) vs. **target listens**, attacker dials in
Switch spoofing	Double tagging	**Full trunk, two-way** via DTP vs. **one-directional** via the native VLAN
Staged payload	Stageless payload	**/** separator, downloads the stage vs. **_** separator, self-contained (egress filtering)
Default creds	Brute force	**Known values**, targeted vs. **guessing** many combinations
Online (Hydra)	Offline (Hashcat)	Hits a **live login** (lockout risk) vs. cracks a **captured hash** (fast, quiet)
psexec.py	wmiexec.py	**Creates a service** (louder) vs. **uses WMI** (stealthier, no service)
Responder capture	Poison-only mode	Grabs the hash itself vs. **steps aside so ntlmrelayx** can relay it

EXAM

Decoding any 4.2 scenario

Four questions, then the final rules that resolve the close calls.

Condition?

What in the environment makes an attack possible — SMB signing off, DTP on, native VLAN match, cleartext protocol?

Tool?

Which tool's unique capability fits — the one thing only it does well.

Outcome?

What the attack actually yields — a hash, a shell, a pivot, a cert, admin.

Risk?

What it introduces — lockout, noise/alerts, service crash, detection.

- **Read the environment first** — Windows vs Linux, switched vs hub, domain vs workgroup decides which attacks even apply.
- **Tool selection is contextual** — know each tool's primary purpose and its one unique capability.
- **Check prerequisites** — SMB signing disabled for relay, native VLAN match for double tagging, DTP enabled for switch spoofing.
- **Follow the chain** — Responder feeds ntlmrelayx, Nmap feeds Metasploit, share enum feeds credential attacks.
- **Egress filtering → stageless**; reliability concern → staged.
- **Network devices → default credentials first**, before anything complex.

REFERENCE

Keyword quick reference

The terms most likely to anchor a scenario, with the single association that matters.

KEYWORD	ASSOCIATION
SMB signing	Defense against relay; if **disabled**, relay is possible
LLMNR / NBT-NS	Name-resolution fallback poisoned by Responder
NTLM relay	Forward auth without cracking (ntlmrelayx)
ESC1	Cert template allowing SAN specification → any-user cert
ESC8	NTLM relay to AD CS web enrollment
DTP	Dynamic Trunking Protocol, exploited in switch spoofing
native VLAN	Required for double-tagging
802.1Q	VLAN tagging standard
multihomed	Host on multiple networks → pivot point
null session	Unauthenticated SMB connection for enumeration
SYSVOL / GPP cpassword	DC share; legacy Group Policy credential storage (MS14-025)
Pwn3d!	CrackMapExec output — admin access confirmed
Meterpreter	Advanced in-memory post-ex payload
staged vs stageless	/ downloads a stage · _ is self-contained (egress)
LHOST / LPORT	Attacker IP/port for payload callbacks
NTLMv2	Hash type Responder captures
rockyou.txt	The go-to wordlist (Hydra/Hashcat)
Scapy	Python packet crafting (NULL/Xmas/FIN, fragmentation)
reverse shell	Target connects back — beats inbound firewalls
secretsdump / NTDS.dit	Impacket dumps domain hashes